

Ejercicio 1: Risk Storming y Riesgos Modernos

Contexto: Una fintech está desarrollando una nueva aplicación móvil de préstamos que utiliza una API de Inteligencia Artificial de un tercero para evaluar el riesgo crediticio de los usuarios, y toda la infraestructura está alojada en un único proveedor de nube (Serverless). Realice un Risk Storming simulado, identifique 4 riesgos específicos para este proyecto, uno de cada categoría:

- (a) Técnico / Deuda Técnica
- (b) Ciberseguridad / Cadena de suministro
- (c) Vendor Lock-in
- (d) Ético o Legal (IA)

Para el riesgo de mayor puntuación, aplique un análisis cualitativo (asigne valores de Probabilidad 1-5 e Impacto 1-5) y calcule el Risk Score. Proponga una estrategia de respuesta concreta (Evitar, Mitigar, Transferir o Aceptar) y describa cómo se traduciría esta mitigación en una tarea tangible dentro de un Sprint Backlog (ej. un Spike o una historia de seguridad).

1. Riesgos Identificados

Riesgo Técnico / Deuda Técnica

Debido a la presión por lanzar el producto rápidamente al mercado, existe el riesgo de que el equipo de desarrollo integre la llamada a la API de evaluación crediticia directamente dentro del flujo principal de la aplicación, sin construir una capa de abstracción intermedia. Si bien esta decisión acelera el desarrollo a corto plazo, genera una acumulación de deuda técnica: si la fintech decide cambiar de proveedor de IA o incorporar un segundo proveedor como respaldo, el equipo tendría que modificar código fuertemente acoplado a esa integración específica, incrementando tanto el esfuerzo requerido como la probabilidad de introducir errores en producción.

Riesgo de Ciberseguridad / Cadena de Suministro

La aplicación transmite datos financieros y personales sensibles de los usuarios a la API externa de terceros para su evaluación crediticia. Si dicha API presenta una vulnerabilidad no detectada, o si el proveedor sufre una brecha de seguridad, los datos de los usuarios podrían quedar expuestos sin que la fintech haya sido atacada directamente. El punto débil no reside en la infraestructura propia de la organización, sino en un componente externo del que depende su funcionamiento.

Riesgo de Vendor Lock-in

Al alojar toda la infraestructura en un único proveedor de nube mediante una arquitectura Serverless, que emplea servicios propietarios específicos de dicho proveedor, la fintech queda condicionada a sus términos comerciales y técnicos. Un incremento significativo en los precios, un cambio en las condiciones de servicio, o una interrupción prolongada del proveedor dificultarían una migración oportuna hacia otra plataforma, comprometiendo la capacidad de

respuesta de la organización ante contingencias externas.

Riesgo Ético / Legal (Inteligencia Artificial)

El algoritmo de evaluación de riesgo crediticio, al ser desarrollado y operado por un tercero, podría contener sesgos heredados de los datos utilizados durante su entrenamiento. Estos sesgos podrían derivar en discriminación indirecta hacia determinados grupos de usuarios (por ejemplo, en función de la zona geográfica, el género o el nivel socioeconómico), generando negativas de préstamo injustificadas. Esta situación expondría a la fintech a posibles demandas por discriminación algorítmica y a sanciones por incumplimiento de normativas de protección al consumidor financiero.

2. Análisis Cualitativo de los Riesgos Identificados

Escala utilizada:

- **Probabilidad:** 1 = Muy improbable, 5 = Casi seguro.
- **Impacto:** 1 = Insignificante, 5 = Catastrófico.
- **Risk Score:** Probabilidad × Impacto.
- **Niveles:** Bajo (1–4), Medio (5–9), Alto (10–15), Crítico (16–25).

Categoría	Riesgo	Probabilidad	Impacto	Risk Score	Nivel
Técnico / Deuda Técnica	Integración directa con la API de IA sin capa de abstracción	4	3	12	Medio
Ciberseguridad / Cadena de Suministro	Brecha en la API externa que expone datos financieros y personales	4	5	20	Crítico
Vendor Lock-in	Dependencia total de un único proveedor cloud serverless	3	4	12	Medio
Ético / Legal (IA)	Sesgo algorítmico en la evaluación crediticia	3	5	15	Alto

Riesgo de mayor puntuación: Ciberseguridad / Cadena de Suministro — Risk Score = 20/25 (Crítico).

3. Análisis Cualitativo del Riesgo de Mayor Puntuación

Riesgo: La aplicación transmite datos financieros y personales sensibles a una API externa de IA para evaluar el riesgo crediticio. Si esa API tiene una vulnerabilidad no detectada o el proveedor sufre una brecha, los datos de los usuarios pueden quedar expuestos sin que la fintech haya sido atacada directamente.

Probabilidad: 4/5

Es altamente probable porque:

- La fintech depende de un tercero para una función crítica.
- La superficie de ataque incluye la API, credenciales, configuración serverless y flujo de datos.
- Los incidentes en cadenas de suministro de software son frecuentes.
- La infraestructura propia no controla la seguridad interna del proveedor.

Impacto: 5/5

El impacto sería catastrófico porque:

- Se expondrían datos financieros y personales de usuarios.
- Habría sanciones por incumplimiento de normativas de protección de datos.
- Se afectaría la reputación y la confianza de los clientes.
- Podrían surgir demandas, fraude y pérdida de licencia operativa.
- Se interrumpiría el servicio de préstamos.

Risk Score: $4 \times 5 = 20 \rightarrow$ **Crítico.**

4. Estrategia de Respuesta

Estrategia principal: Mitigar.

No conviene solo aceptar el riesgo por su alto impacto regulatorio y reputacional. Tampoco se puede evitar por completo porque la API de IA es parte central del producto. Se mitiga reduciendo la probabilidad y el impacto, y se complementa con transferencia parcial mediante contrato y seguro cibernético.

Acciones concretas de mitigación:

- **Minimización de datos:** enviar solo lo estrictamente necesario a la API externa.
- **Tokenización o seudonimización** antes de enviar datos personales.
- **Capa intermedia obligatoria:** API Gateway o servicio proxy propio.
- **Cifrado en tránsito** con TLS 1.3 y autenticación mutua si es posible.
- **Gestión de secretos** en vault con rotación automática.
- **Registro y auditoría** de llamadas sin almacenar PII en logs.
- **Monitoreo de anomalías**, rate limiting y alertas tempranas.
- **Evaluación de seguridad del proveedor** y cláusulas de notificación de brechas.
- **Plan de respuesta a incidentes** con plazos de notificación.
- **Seguro cibernético** y acuerdos de responsabilidad contractual.

5. Traducción al Sprint Backlog

Spike Propuesto

Título: Spike de seguridad y privacidad en la integración con la API de IA crediticia.

Tipo: Spike timeboxed a 1 sprint.

Objetivo: Mapear el flujo de datos sensibles, evaluar controles del proveedor y definir la arquitectura de mitigación antes de implementar.

Entregables:

- Diagrama de flujo de datos con puntos de exposición.
- Identificación de PII y datos financieros enviados.
- Evaluación de seguridad del proveedor externo.
- Decisión arquitectónica: proxy, tokenización y minimización.
- Backlog de controles priorizados.

Criterio de aceptación: Informe revisado por seguridad y arquitectura, con recomendación clara de controles mínimos antes de pasar a producción.